

Projet- Détection d'attaques inconnues par Anomaly Detection

1. Contexte et mission

Un SOC souhaite explorer une approche qui n'exige pas d'exemples de toutes les attaques possibles. L'équipe doit étudier si l'apprentissage du comportement normal permet de détecter des événements inconnus.

Question centrale : Peut-on détecter des attaques inconnues sans disposer d'exemples de ces attaques pendant l'entraînement ?

2. Objectifs pédagogiques

- Formuler des hypothèses testables à partir d'une problématique de cybersécurité.
- Concevoir un protocole expérimental reproductible et éviter les fuites de données.
- Comparer plusieurs méthodes de Machine Learning avec des métriques adaptées.
- Analyser les erreurs, la généralisation et la robustesse plutôt que rechercher uniquement la meilleure accuracy.
- Interpréter les résultats du point de vue Machine Learning et du point de vue cybersécurité.
- Défendre les choix méthodologiques et les conclusions lors d'une soutenance.

3. Organisation indicative des 21 heures

Phase	Durée	Travail
Phase 1	2 h	Problématique, compréhension du dataset, EDA ciblée
Phase 2	2 h	Préparation des données, pipeline et baseline
Phase 3	3 h	Expérience 1
Phase 4	4 h	Expérience 2
Phase 5	4 h	Expérience 3
Phase 6	3 h	Analyse approfondie, explicabilité et comparaison
Phase 7	3 h	Synthèse, rapport et préparation de la soutenance

4. Travail expérimental obligatoire

Expérience 1 — Comparaison de détecteurs d'anomalies

Protocole. Comparer au minimum Isolation Forest, Local Outlier Factor et One-Class SVM, ou justifier une alternative. Les paramètres et le protocole doivent être comparables.

Hypothèse à tester. H1 : les méthodes auront des compromis différents entre détection et faux positifs.

Résultats/figures attendus. Recall, Precision, F1, FPR et distribution des anomaly scores.

Expérience 2 — Contamination

Protocole. Construire des jeux d'entraînement supposés normaux avec 0 %, 1 %, 2 %, 5 % puis 10 % de contamination par des attaques. Réentraîner et mesurer la dégradation.

Hypothèse à tester. H2 : l'augmentation de la contamination réduira la capacité à distinguer normal et attaque.

Résultats/figures attendus. Courbes contamination vs Recall/FPR/F1.

Expérience 3 — Simulation Zero-Day

Protocole. Choisir plusieurs familles d'attaques totalement absentes de l'apprentissage. Comparer leur détection par les modèles d'anomalies et par un classifieur supervisé entraîné sans ces familles.

Hypothèse à tester. H3 : certaines méthodes d'anomalies seront moins précises globalement mais plus utiles sur certaines familles inconnues.

Résultats/figures attendus. Comparaison Known/Unknown et analyse par famille.

5. Méthodologie commune exigée

- Définir clairement les jeux d'entraînement, validation et test. Toute décision utilisant le jeu de test doit être signalée et justifiée.
- Construire une baseline avant les modèles plus complexes.
- Comparer au minimum trois modèles ou méthodes lorsque le sujet le permet.
- Utiliser des métriques adaptées au déséquilibre des classes : Precision, Recall, F1-score, Macro-F1, PR-AUC, FPR ou autres selon le problème.
- Conserver des conditions expérimentales comparables entre les modèles.
- Fixer les graines aléatoires lorsque cela est possible et documenter les versions principales des bibliothèques.
- Analyser les faux positifs et faux négatifs ; ne pas commenter uniquement une métrique globale.
- Inclure une méthode d'interprétation ou d'explicabilité adaptée : feature importance, permutation importance, SHAP ou méthode équivalente.
- Distinguer explicitement : observation expérimentale, interprétation ML, interprétation cybersécurité et limite de l'étude.

6. Questions d'analyse obligatoires

Q1. Une anomalie est-elle nécessairement une attaque ?

Q2. Quelles attaques ressemblent trop au trafic normal ?

Q3. Quel niveau de faux positifs serait acceptable dans un SOC ?

Q4. Pourquoi cette expérience ne suffit-elle pas à prouver la détection de tous les zero-day ?

7. Utilisation de l'intelligence artificielle

Les outils d'IA générative peuvent être utilisés comme assistance, mais ils ne remplacent ni la conception expérimentale ni l'analyse des résultats. Le groupe reste responsable de l'intégralité du travail rendu.

- L'IA peut aider à expliquer une API, proposer une structure de code, déboguer ou améliorer la rédaction.
- Chaque membre doit être capable d'expliquer le code, les modèles, les métriques et les choix expérimentaux.
- Les résultats, graphiques et conclusions doivent provenir des expériences réellement exécutées par le groupe.
- Toute utilisation significative d'un outil d'IA doit être déclarée brièvement dans une section « Utilisation de l'IA » du rapport.
- Un résultat généré ou affirmé par une IA sans vérification expérimentale ne constitue pas une preuve.

8. Organisation du groupe

Vous travaillez à quatre. Vous pouvez répartir les responsabilités principales, mais le projet constitue un travail collectif. Lors de la soutenance, chaque étudiant peut être interrogé sur n'importe quelle partie.

9. Livrables

- Notebook Jupyter/Google Colab propre, exécutable et commenté.
- Rapport de 10 à 15 pages hors annexes, présentant la question de recherche, les hypothèses, le protocole, les résultats, l'analyse et les limites.
- Présentation de 10 à 15 diapositives.
- Soutenance : 15 minutes de présentation + 5 minutes de questions.
- README indiquant les étapes nécessaires pour reproduire les expériences.
- Section courte décrivant l'utilisation éventuelle d'outils d'IA générative.

10. Structure attendue pour chaque expérience

Élément	Contenu attendu
Question de recherche	Ce que l'expérience cherche à déterminer.
Hypothèse	Résultat attendu avant d'exécuter l'expérience.
Protocole	Données, split, modèles, paramètres contrôlés et métriques.
Résultats	Tableaux, figures et mesures réellement obtenus.
Analyse	Explication des observations et comparaison aux hypothèses.
Interprétation cyber	Conséquences possibles dans un système de sécurité réel.

Limites	Ce que l'expérience ne permet pas de conclure.
---------	--

11. Points de vigilance

- Ne pas utiliser l'accuracy seule pour conclure.
- Ne pas effectuer de feature selection, scaling ou rééchantillonnage sur l'ensemble complet avant le split.
- Ne pas présenter une corrélation comme une relation causale.
- Ne pas qualifier une attaque d'« inconnue » si des observations de cette même famille ont servi à l'entraînement.
- Ne pas choisir le meilleur modèle uniquement sur le jeu de test.
- Toute conclusion doit être reliée à un résultat mesuré.